

What is IDOR?

- Access control vulnerability where user-supplied input is used to retrieve objects (files, data, documents)
- Server fails to validate if requested object belongs to the requesting user
- Occurs when too much trust is placed on input data

Basic Example:

- Normal: `http://site.com/profile?user_id=1305`
 - IDOR test: Change to `http://site.com/profile?user_id=1000`
 - If you see another user's data = IDOR found
-

IDOR in Different ID Formats:

Encoded IDs (Base64)

- Common encoding on web
- Characters: a-z, A-Z, 0-9, = (padding)
- Decode → modify → re-encode → resubmit
- Tools: <https://www.base64decode.org> / <https://www.base64encode.org>

Hashed IDs

- May follow predictable patterns (e.g., md5 of integer)
- Test with: <https://crackstation.net>
- Example: ID 123 → md5 = 202cb962ac59075b964b07152d234b70

Unpredictable IDs

- Create two accounts
 - Swap ID numbers between them while logged in
 - If you can view other user's content = valid IDOR
-

Where to Find IDORs:

Not just in address bar:

- AJAX requests loading content
- JavaScript files referencing endpoints
- Hidden/unreferenced parameters from development

Parameter Mining:

- Find unreferenced parameters that may still work
 - Example: See `/user/details` (authenticated via session)
 - Discover hidden parameter: `/user/details?user_id=123`
 - Test by changing `user_id` value
-

Practical Testing Approach:

1. Look for requests that reference objects by ID (in URL, POST data, cookies)
2. Test by modifying ID to different values
3. Check if you can access data belonging to other users
4. Test while logged in as different account or not logged in